

ISO/IEC 27001: 2022

Information Security Management System (ISMS)

Portfolio Project | NexaTech Solutions | 2024

Prepared By	Organization	Standard	Date
Cybersecurity Analyst	NexaTech Solutions	ISO/IEC 27001: 2022	2024

1. Executive Summary

This document presents a comprehensive ISO/IEC 27001:2022 Information Security Management System (ISMS) portfolio project developed for NexaTech Solutions, a 120-person software development company. The project demonstrates the full ISO 27001 implementation lifecycle, including scoping, risk assessment, Annex A control selection, implementation, internal audit, and the Statement of Applicability.

ISO 27001 is an internationally recognized information security standard used across industries and countries. Unlike HIPAA (healthcare-specific) or NIST CSF (U.S. guidance framework), ISO 27001 is globally certifiable and applies to organizations of all sizes and industries.

ITEM	DETAIL
Organization	Nexa Tech Solutions
Industry	Software / Technology SaaS
Employees	120 staff members
Standard	ISO/IEC 27001: 2022
Scope	All information assets supporting client software delivery

Certification Body	BSI Group (simulated)
Project Status	ISMS is implemented / Ready for Certification audit

2. What is ISO 27001?

2.1 Plain English Explanation

ISO 27001 is an internationally recognized standard outlining how companies establish, maintain, and continually improve an Information Security Management System (ISMS). It is a comprehensive security program covering people, processes, and technology.

Comparison with other frameworks:

- NIST CSF: U.S. guidance; no certification; any industry.
- HIPAA: U.S. federal law; healthcare-specific; no certification.
- ISO 27001: International standard; any industry; globally certifiable.

2.2 The PDCA Cycle / How ISO 27001 Works

ISO 27001 uses a continuous improvement model called the PDCA cycle. Security is never done. It is an ongoing process of planning, implementing, checking, and improving.

Phase	Name	What You Do
PLAN	Build Your ISMS	Define scope, identify access, conduct risk assessment, establish the right security policy, and set objectives.
DO	Implement Controls	Deploy Annex, a controlled train, employees installed technical safeguards, and document everything
CHECK	Monitor & Audit	Conduct internal audit measures, control effectiveness, and manage review meetings.
ACT	Fix & Improve	Correct failures, update policy, supply improvements, and restart the cycle

3. Organizational Context Scope

3.1 Company Overview

NexaTech Solutions develops cloud-hosted enterprise software. The company stores sensitive client data, proprietary source code, and employee information across AWS cloud services and on-premises infrastructure.

Asset Category	Asset Included in ISMS Scope
Data Asset	Client database, 50,000 records, source code repository, employee HR records, financial data
Hardware	120 employees, laptops, 8 on-site servers, network switches, and firewalls
Software	AWS cloud infrastructure, GitHub Enterprise, Microsoft 365, Jira, Confluence
Facilities	Atlanta HQ office, AWS data centers, US East-1 and US West-2
People	120 employees, 15 contractors, 83rd party vendors with system access
Services	Customer-facing SaaS platform, internal development tools, email, and collaboration

3.2 Interested Parties

- Enterprise clients requiring ISO 27001 certification
- Employees and contractors handling sensitive information
- SOC 2 auditors and regulatory agencies
- Third-party vendors with system access
- Investors and board members are monitoring the security posture

4. Risk Assessment (ISO 27001 Clause 6.1 2)

ISO 27001 requires a documented risk assessment using the formula:

Risk Score = Likelihood (1–5) × Impact (1–5)

Scores ≥ 12 = High Priority, requiring treatment.

Risk/Treatment	Likelihood (1-5)	Impact (1-5)	Score	Priority	Treatment
Source code stolen by an insider	3	5	15	HIGH	Implemented DLP software to restrict repo access, monitor git activity
Client data breach via unsecured API	3	5	15	HIGH	API security testing, OAuth 2.0, rate limiting, encryption
Ransomware attack on cloud servers	3	4	12	HIGH	Daily backups, EDR software patch management within 30 days
Phishing credential theft	4	3	12	HIGH	MFA on all accounts, phishing simulation training quarterly
Third-party vendor breach	2	4	8	MED	Vendors' assessment BAAs annual security questionnaires
Employee laptop theft	2	3	6	LOW	Full disk encryption, remote white compatibility, asset tracking

Note: This risk assessment satisfies the requirements of ISO 27001 clauses 6.12 (information security risk assessment) and 6.13 (information security), and has been assigned an owner and a treatment deadline.

5. Annex A Security Controls

ISO 27001:2022 Annex A includes 93 controls across four categories. Below are controls applicable to NexaTech, along with implementation status.

5.1 Organizational Controls (37 controls)

Clause	Control	Status	Implementation at Nexa Tech
5.1	Information Security Policies	COMPLETE	Written policy approved by CEO; reviewed annually

5.2	Information Security Roles	COMPLETE	CISO appointed; responsibilities documented
5.15	Access control policy	COMPLETE	RBAC enforced; quarterly access reviews
5.24	Incident Management	COMPLETE	IR plan documented and tested Q2 2024
5.29	Business Continuity	COMPLETE	BCP tested; RTO 4 hours, RPO 24 hours
5.36	Compliance	COMPLETE	Legal requirements mapped; annual reviews

5.2 People Controls (8 Controls)

Clause	Control	Status	Implementation at Nexa Tech
6.1	Screening	COMPLETE	Background checks were completed for 120 employees and 15 contractors before the higher
6.3	Security Awareness Training	COMPLETE	Annual security training program 100% completion rate record, retaining 3 years
6.4	Disciplinary	COMPLETE	HR policy includes disciplinary procedures for security policy violations
6.5	Responsibilities After Termination	COMPLETE	Offboarding checklist: all access remote on the last day of employment

5.3 Physical Controls (14 controls)

Clause	Control	Status	Implementation at Nexa Tech
7.1	Physical Security Perimeter	COMPLETE	Key card access to the office server room requires a secondary badge; a visitor log is maintained
7.3	Securing Offices and Rooms	COMPLETE	Clean desk policy enforced; screen locks required; security cameras at all entrances
7.8	Equipment Sitting	COMPLETE	Servers in a locked room; no sensitive equipment visible through the windows
7.14	Secure Disposal	COMPLETE	NIST SP 800 - 88 data sanitations certify of

			destruction maintained for all disposed hardware
--	--	--	--

5.4 Technological Controls (34 controls)

Clause	Control	Status	Implementation at Nexa Tech
8.2	Privilege access management	COMPLETE	15 admin accounts with MFA, PAM tool (CyberArk), quarterly privilege reviews
8.5	Multifactor authentication	COMPLETE	MFA in Forest on 120 employee accounts via Microsoft Authenticator
8.7	Protected against malware	COMPLETE	CrowdStrike EDR on all endpoints; daily signature updates; weekly scam reports
8.24	Use of cryptography	COMPLETE	AES-256 encryption at rest; TLS 1.3 in transit; encryption key management policies
8.40	Vulnerability management	IN PROGRESS	Nessus scans monthly; patching SLA 30-day critical; 60 days high; 2 servers behind

6. Internal Audit Results (ISO 27001 Clause 9.2)

ISO 27001 requires organizations to conduct internal audits at planned intervals to verify that the ISMS is effectively implemented and maintained. The following audit was conducted on October 15, 2024, covering the period January 1 — September 30, 2024.

Control Areas	Requirement	Finding	Result	Corrective Action
Access Control	MFA on all admin accounts	3 or 15 admin missing MFA	FAIL	Enabled MFA immediately; Deadline line 7 days from order date
Encryption	All ePHI is encrypted at rest	AWS S3 bucket found on encrypted	FAIL	Enable history default encryption; Did my 48 hours
Security training	100% staff trained annually	All 120 staff trained and documented	PASS	No action required; maintain records

Patch management	Patches apply within 30 days	Two servers 45 days past due	FAIL	Apply patches within 5 days
Incident response	IR plan tested annually	Plan tested Q2 2024; documented	PASS	Schedule Q4 2024 tabletop exercise
Vendor management	BAAs signed with all vendors	One vendor is missing the signed BAA	WARN	Request sign BAA; deadline 14 days
Physical security	Server room key card access	All access logs verify complete	PASS	No action required

Audit Summary

Total Controls Tested	Passed	Failed	Warnings
7	3 PASSED	3 FAILED	1 WARNINGS

7. Statement of Applicability (SoA)

The Statement of Applicability is a mandatory ISO 27001 document (Clause 6.13d) that lists all 93 Annex A controls, indicates whether each is included or excluded, and provides a written justification for each. This document is the certification auditor's primary evidence review.

Control	Control Name	Included ?	Justification
8.5	Multifactor authentication	YES	All 120 accounts required MFA; risk RA-04 (credential theft) rated HIGH
8.24	Use of Cryptography	YES	Client data encrypted AES-256; TLS 1.3 enforced per policy SEC-12
7.4	Physical Security Monitoring	NO	NexaTech is cloud-first; no physical data centers are operated. CCTV not in scope
8.7	Protection from Malware	YES	CrowdStrike EDR deployed on endpoints; daily updates; 99.8% protection rate

5.29	Business Continuity	YES	BCP documented and tested Q1 2024. RTO: 4 hours. RPO: 24 hours.
6.3	Security Awareness Training	YES	Annual training 100% completion; records retained 3 years per policy HR-07
8.40	Vulnerability Management	YES	Monthly Nessus scans; patching SLA enforced; remediation tracker in Jira
5.36	Compliance with Legal Requirements	YES	Legal register maintenance; GDPR, SOC 2, contractual obligations map